

# Static Security Analysis of AWS IAM Policies for AI Workload Identities

Detecting Excessive Privilege and Identity-Pivot Risks Before Deployment

github.com/poojakira/aws-agent-identity-guard - public, default branch main.

EVIDENCE POSTURE

Verified, scoped, reproducible

Claims are constrained to the repository evidence snapshot and stated limitations.

243

Tests collected

240

Tests passed

3

Tests skipped

25

Deterministic rule IDs

SYSTEM VIEW

## Architecture and Threat-Control Flow

### Trust Boundary

#### Input surface

Data, models, requests, policies, or artifacts entering the tested path.

#### Control surface

Repository-specific validation, analysis, and fail-closed checks.

#### Evidence surface

Findings, metrics, tests, logs, or reproducible artifacts.

This diagram describes the tested repository path, not a universal deployment guarantee.

01

Parse one IAM policy document without executing cloud actions.

02

Classify statements and trust-policy structure.

03

Apply deterministic rule checks for privilege escalation, excessive privilege, trust weaknesses, audit tampering, and missing boundaries.

04

Emit findings with stable rule IDs and severity.

05

Return CI-friendly exit codes and optional SARIF.

### Research Contribution

A deterministic, non-executing IAM linter specialized for AI-agent roles with 25 rule IDs spanning identity policies, trust policies, and permission-boundary risks, emitting text, JSON, and SARIF for pre-deployment review and CI gating.

### Verified Evidence

**EV-01** 243 collected; 240 passed, 3 skipped, 0 failures/errors.

**EV-02** 25 deterministic rule IDs remain implemented and test-covered.

**EV-03** Current performance gate over 500 synthetic policies: 0.8397 ms p95 and 2,573 policies/sec, both passing configured gates.

**EV-04** Ruff/format and security-audit jobs complete successfully.

**EV-05** Synthetic-policy p95: 0.8397 ms

**EV-06** Synthetic-policy throughput: 2,573 policies/sec

### Method and Control Path

**01** Parse one IAM policy document without executing cloud actions.

**02** Classify statements and trust-policy structure.

**03** Apply deterministic rule checks for privilege escalation, excessive privilege, trust weaknesses, audit tampering, and missing boundaries.

**04** Emit findings with stable rule IDs and severity.

**05** Return CI-friendly exit codes and optional SARIF.

### Limitations and Residual Risk

- No additional limitation text was found in the research brief. Consult the README before generalizing results.

### Reproducibility

Expected test evidence: 240 passed, 3 skipped.

### Evidence Provenance

#### Claim discipline

Metrics come from the repository's verified metrics and research brief.

#### Scope discipline

Benchmarks are reported only at their documented fixture, dataset, or test scope.

#### Reproduction

PDF and PNG are generated locally from committed evidence without paid services.